Comprehensive AI/ML Bug Bounty Reconnaissance & Testing Checklist

Version: 1.0
Audience: Bug Bounty Hunters, Security Researchers, Red Teams, AI Security Engineers
Scope: AI/ML Systems, APIs, Infrastructure, Data Pipelines

Author: M. Fawad Qureshi
Usage Note: This checklist must be used **only with explicit authorization** and **alongside traditional application security testing**.

Phase 1: AI-Specific Reconnaissance

1.1 AI Component Discovery

- Identify AI/ML endpoints
  - /api/v1/predict, /model/inference, /ai/chat
- Locate model serving platforms
  - TensorFlow Serving, TorchServe, Triton Inference Server
- Identify training and management interfaces
  - /mlflow, /kubeflow, /train
- Discover AI API documentation
  - Swagger / OpenAPI specifications
- Identify real-time inference channels
  - WebSocket, WebRTC
- Enumerate GraphQL endpoints with AI queries or mutations
- Locate edge AI and on-device inference endpoints

1.2 AI Service Fingerprinting

- Identify ML frameworks
  - TensorFlow, PyTorch, Scikit-learn, ONNX
- Detect model artifacts
  - .h5, .pb, .pt, .onnx, .joblib
- Identify hardware accelerators
  - GPU, TPU, Inferentia
- Map AI microservices architecture
- Identify containerized AI services
  - Docker, Kubernetes (AI pods)
- Discover serverless AI workloads

- AWS Lambda, Google Cloud Functions

1.3 AI Data Pipeline Discovery

- Locate data ingestion endpoints
- Identify feature store APIs
- Discover data labeling and annotation interfaces
- Identify data versioning systems (e.g., DVC)
- Locate preprocessing and transformation services
- Identify data augmentation pipelines
- Discover synthetic data generation services

Phase 2: AI Model Interaction Testing

2.1 Prompt Injection & Manipulation

- Test direct prompt injection in LLM systems
- Attempt indirect prompt injection via external data sources
- Identify prompt leakage through error messages
- Attempt model jailbreaking techniques
- Test training data extraction via crafted prompts
- Attempt privilege escalation using prompt engineering
- Test context window overflow attacks
- Attempt prompt injection in multi-step AI workflows

2.2 Model Evasion & Adversarial Attacks

- Test adversarial inputs (text, image, audio)
- Attempt model inversion attacks
- Test membership inference attacks
- Attempt model stealing or reconstruction
- Test adversarial example transferability
- Attempt data poisoning via inference APIs
- Test fairness and bias exploitation
- Attempt backdoor trigger activation

2.3 Model Data Exploitation

- Test training data leakage
- Attempt model parameter extraction
- Identify sensitive information in predictions
- Attempt reconstruction of private data
- Test memorization attacks

- Attempt differential privacy bypass
- Test dataset fingerprinting techniques
- Attempt synthetic data reverse engineering

Phase 3: AI API & Endpoint Security

3.1 API-Specific AI Testing

- Test excessive resource consumption (inference DoS)
- Attempt rate limit bypass on AI endpoints
- Test model version confusion
- Attempt unauthorized model hot-swapping
- Test unauthorized model deployment
- Attempt training job injection or modification
- Manipulate inference pipelines
- Attempt batch job hijacking

3.2 Authentication & Authorization

- Test unauthenticated access to AI models
- Attempt escalation to premium or restricted models
- Test API key reuse across AI services
- Attempt JWT manipulation for AI endpoints
- Test SSO bypass in AI dashboards
- Attempt OAuth token theft
- Identify hardcoded credentials in AI containers
- Attempt service account privilege escalation

Phase 4: AI Infrastructure & Deployment Security

4.1 Container & Orchestration

- Test exposed Docker sockets
- Attempt container escape from ML workloads
- Identify sensitive data in container images
- Attempt Kubernetes API access
- Test exposed GPU or driver interfaces
- Attempt node-level compromise via AI workloads
- Test insecure volume mounts
- Attempt cross-tenant access in shared clusters

4.2 Model Repository & Registry

- Test unauthorized model upload/download
- Attempt model artifact tampering
- Test model version manipulation
- Attempt poisoning of public model registries
- Identify insecure model storage
- Attempt metadata injection
- Test race conditions in model deployment
- Attempt denial-of-service on model serving

Phase 5: AI Data Pipeline Security

5.1 Training Pipeline Attacks

- Test training data poisoning
- Attempt feature manipulation
- Test label flipping attacks
- Attempt hyperparameter tampering
- Test gradient leakage
- Attempt federated learning compromise
- Test distributed training attacks
- Attempt checkpoint poisoning

5.2 Feature Store & Validation

- Test feature injection
- Attempt feature store pollution
- Test statistical skew manipulation
- Attempt data drift exploitation
- Test schema poisoning
- Attempt data lineage manipulation
- Test metadata corruption
- Attempt data rollback attacks

Phase 6: AI Client-Side Security

6.1 Browser-Based AI

- Test WebGL-based ML exploitation
- Attempt TensorFlow.js model theft

- Test client-side model poisoning
- Attempt WebAssembly ML attacks
- Test model caching vulnerabilities
- Attempt local storage manipulation
- Extract ML data from IndexedDB
- Attempt service worker hijacking

6.2 Mobile AI Applications

- Identify exposed Core ML / TFLite models
- Attempt model extraction from mobile apps
- Test insecure on-device model storage
- Attempt ML Kit / ARKit exploitation
- Test biometric model bypass
- Attempt on-device training data leakage
- Test model update mechanisms
- Attempt federated learning client compromise

Phase 7: AI Supply Chain Security

7.1 Third-Party AI Components

- Identify vulnerable ML dependencies
- Test poisoned pre-trained models
- Identify malicious pipelines or notebooks
- Attempt dataset supply chain attacks
- Test compromised AI SaaS integrations
- Attempt API key leakage
- Test vulnerable Jupyter kernels
- Attempt notebook injection

7.2 AI Development Tools

- Exploit ML development environments
- Attempt code injection in notebooks
- Identify credential leakage in configurations
- Insert backdoors in AutoML pipelines
- Test model serialization vulnerabilities
- Attempt pickle exploitation
- Test experiment tracking security
- Attempt MLflow artifact tampering

Phase 8: Advanced AI-Specific Attacks

8.1 Multimodal AI

- Test cross-modal prompt injection
- Attempt vision-language manipulation
- Test audio-visual bypass techniques
- Attempt sensor fusion exploitation
- Test multimodal data poisoning
- Attempt coordinated multi-model attacks
- Test ensemble manipulation

8.2 Reinforcement Learning

- Test reward hacking
- Attempt environment poisoning
- Extract trained policies
- Manipulate training processes
- Exploit exploration strategies
- Attempt transfer learning abuse
- Compromise multi-agent systems
- Attempt meta-learning manipulation

Phase 9: AI Privacy & Compliance

9.1 Privacy Attacks

- Test model inversion
- Attempt attribute inference
- Test property inference
- Attempt data reconstruction
- Exploit privacy budget weaknesses
- Attack differential privacy parameters
- Bypass secure aggregation
- Test homomorphic encryption side channels

9.2 Regulatory Compliance

- Test GDPR violations
- Identify HIPAA data leakage
- Test CCPA / CPRA compliance
- Attempt PCI DSS bypass
- Test algorithmic bias

- Manipulate fairness metrics
- Test explainability and transparency
- Attempt accountability bypass

Phase 10: Specialized AI Systems

10.1 Computer Vision

- Test adversarial patches
- Perform physical-world attacks
- Bypass object detection
- Spoof facial recognition
- Manipulate segmentation models
- Poison OCR systems
- Exploit video analytics
- Attack depth estimation

10.2 NLP & Language Models

- Bypass toxic content filters
- Manipulate sentiment analysis
- Evade text classification
- Attack NER systems
- Poison machine translation
- Manipulate summarization
- Bypass chatbot controls
- Exploit code generation

10.3 Autonomous & Robotics

- Spoof sensors
- Manipulate control signals
- Exploit planning algorithms
- Attack SLAM systems
- Hack RL policies
- Exploit sim-to-real gaps
- Compromise multi-robot systems
- Manipulate human-in-the-loop workflows

Phase 11: AI Monitoring & Detection Evasion

11.1 AI Security Bypass

- Evade anomaly detection
- Bypass fraud detection ML
- Evade intrusion detection
- Poison spam filters
- Bypass malware detection
- Defeat CAPTCHA via ML
- Spoof biometric systems
- Evade behavioral analysis

11.2 Defensive AI Exploitation

- Bypass adversarial training
- Attack defensive distillation
- Exploit gradient masking
- Bypass certified defenses
- Manipulate ensemble defenses
- Evade detection-based defenses
- Bypass input transformations
- Exploit randomized defenses

Phase 12: AI Incident Response & Forensics

12.1 Detection & Analysis

- Test ML attack detection
- Manipulate forensic evidence
- Bypass attack attribution
- Poison AI system logs
- Manipulate monitoring metrics
- Induce alert fatigue
- Bypass automated IR
- Manipulate recovery processes

Automation & Tooling Recommendations

AI Security Tools

- **Adversarial Testing:** ART, CleverHans, Foolbox, TextAttack
- **Model Analysis:** SHAP, LIME, Captum, TensorBoard

- **ML Security:** Microsoft Counterfit, IBM ART
- **Data Poisoning:** Poison Frogs, Backdoor Toolkits
- **Model Stealing:** Knockoff Nets, ModelExtraction
- **Membership Inference:** ML Privacy Meter
- **Prompt Security:** Garak, PromptInject, LM Jailbreak
- **AI Fuzzing:** DeepHunter, TensorFuzz, MLFuzz

Custom Automation

- Prompt injection payload generators
- Adversarial example pipelines
- Model extraction automation
- Training data inference scripts
- AI API fuzzers
- Model serialization scanners
- Containerized AI environment testers
- Federated learning simulators

Reporting Guidelines

Required Documentation

- Attack methodology
- Model performance impact
- Data leakage evidence
- Privacy violation proof
- Reproducible attack code
- Mitigation recommendations
- AI-adapted CVSS scoring
- Regulatory impact analysis

Severity Classification

- **Critical:** Training data extraction, model theft, RCE via ML
- **High:** Prompt injection, data poisoning, adversarial evasion
- **Medium:** Model inversion, membership inference
- **Low:** Bias and fairness issues without direct security impact

---

Final Note

This checklist is **AI/ML-specific** and must be used **in combination with traditional web, API, cloud, and mobile security testing methodologies**. Always ensure **explicit authorization** before testing.